# Kiến thức mạng cần học cho dự án phân loại cảnh báo

Dữ liệu dùng: UNSW-NB15. Mục tiêu: hiểu mỗi dòng dữ liệu (một kết nối mạng) đã xảy ra như thế nào, để chọn đặc trưng và giải thích kết quả mô hình. Thời gian dự kiến: 15-20 giờ trong 3 tuần.

> Tên cột và giá trị trong tài liệu này được ghi theo trí nhớ về bộ UNSW-NB15. Khi tải dữ liệu về, hãy đối chiếu với file mô tả đặc trưng đi kèm và sửa lại cho khớp.

## 1. Kết nối (flow) và mô hình TCP/IP

### 1.1 Một kết nối được xác định bởi 5 thứ

IP nguồn, IP đích, port nguồn, port đích, giao thức (TCP/UDP/ICMP). Mỗi dòng trong UNSW-NB15 mô tả một kết nối như vậy, gồm các số đo trong suốt thời gian nó tồn tại. Khi mở một trang web, trình duyệt thường tạo nhiều kết nối (DNS, rồi một hoặc nhiều kết nối TCP tới máy chủ).

### 1.2 Bốn tầng TCP/IP

| Tầng | Việc chính | Ví dụ |
|---|---|---|
| Ứng dụng | Giao thức người dùng thấy | HTTP, DNS, FTP, SMTP, SSH |
| Giao vận | Truyền giữa hai tiến trình, xác định bằng port | TCP, UDP |
| Internet | Định tuyến gói giữa các mạng | IP, ICMP |
| Liên kết | Truyền trong một mạng cục bộ | Ethernet, Wi-Fi, ARP |

Đóng gói: dữ liệu ứng dụng được thêm tiêu đề TCP/UDP, rồi tiêu đề IP, rồi tiêu đề Ethernet trước khi gửi đi. Wireshark cho phép bung từng lớp ra xem.

## 2. Tầng IP

- Địa chỉ IPv4 dạng 4 số (ví dụ 192.168.1.10). Địa chỉ riêng (10.x.x.x, 172.16-31.x.x, 192.168.x.x) chỉ dùng trong mạng nội bộ.
- **TTL**: số bước nhảy tối đa của gói, giảm 1 mỗi lần qua router, về 0 thì gói bị hủy. Giá trị khởi đầu phụ thuộc hệ điều hành (thường gặp: 64 cho Linux/macOS, 128 cho Windows, 255 cho một số thiết bị mạng). Vì vậy TTL quan sát được cho biết sơ bộ nguồn gửi là loại máy nào và cách xa bao nhiêu bước. Cột liên quan: `sttl`, `dttl`.
- Chia nhỏ gói (fragmentation) khi gói lớn hơn MTU (thường 1500 byte).

## 3. TCP (phần quan trọng nhất)

### 3.1 Bắt tay ba bước

```
Client                    Server
  | ---- SYN ------------>  |   xin mở kết nối
  | <--- SYN + ACK -------  |   đồng ý
  | ---- ACK ------------>  |   xác nhận, kết nối mở
  |  ... truyền dữ liệu ... |
  | ---- FIN ------------>  |   xin đóng (có thể từng chiều)
  | <--- FIN + ACK -------  |
```

### 3.2 Các cờ TCP

| Cờ | Ý nghĩa | Gợi ý khi phân tích |
|---|---|---|
| SYN | Bắt đầu kết nối | Rất nhiều SYN mà không có ACK kết thúc là dấu hiệu quét cổng hoặc làm ngập |
| ACK | Xác nhận đã nhận | Có ở hầu hết gói sau gói đầu tiên |
| FIN | Đóng kết nối nhẹ nhàng | Kết nối kết thúc bình thường |
| RST | Hủy kết nối ngay | Cổng đóng, bị từ chối, hoặc ngắt bất thường |
| PSH | Đẩy dữ liệu lên ứng dụng ngay | Thường xuất hiện trong trao đổi tương tác |

### 3.3 Các đại lượng TCP liên quan tới dữ liệu

- **Cửa sổ (window)**: lượng dữ liệu bên nhận cho phép gửi trước khi chờ xác nhận. Cột `swin`, `dwin`.
- **RTT** (thời gian khứ hồi) và thời gian từng bước bắt tay. Cột `tcprtt`, `synack`, `ackdat`.
- **Mất gói và truyền lại**: gói không được xác nhận sẽ gửi lại. Cột `sloss`, `dloss`.
- **Số thứ tự (sequence number)**: cột `stcpb`, `dtcpb`. Hiểu ý tưởng là đủ.

### 3.4 Trạng thái kết nối (cột `state`)

Mô tả kết nối kết thúc ra sao. Ví dụ các giá trị hay gặp (kiểm tra file mô tả để biết chính xác): FIN (đóng bình thường), CON (đang kết nối), INT (bị ngắt), REQ (chỉ có yêu cầu), RST (bị hủy). Hãy tự đoán mỗi trạng thái ứng với mẫu gói nào trong Wireshark.

## 4. UDP và ICMP

- **UDP**: không bắt tay, không đảm bảo giao hàng, không có trạng thái kết nối. Dùng cho DNS, streaming, VoIP. Vì vậy nhiều cột TCP (cờ, cửa sổ, RTT) bằng 0 với UDP.

- **ICMP**: báo lỗi và chẩn đoán (ping, báo "host unreachable"). Không có port. Có thể bị dùng để dò xét mạng.
- Cột `proto` cho biết giao thức. Khi xử lý cần mã hóa cột này thành số vì nó là chữ.

## 5. Port và dịch vụ

| Port | Dịch vụ | Ghi chú |
|---|---|---|
| 20/21 | FTP | Truyền file, không mã hóa |
| 22 | SSH | Đăng nhập từ xa, có mã hóa |
| 23 | Telnet | Đăng nhập từ xa, không mã hóa, đáng ngờ nếu còn mở |
| 25 | SMTP | Gửi email |
| 53 | DNS | Chủ yếu UDP, có thể TCP |
| 80 | HTTP | Web không mã hóa |
| 443 | HTTPS | Web có mã hóa (TLS) |

Port 0-1023 là port hệ thống (well-known). Port nguồn của client thường là số ngẫu nhiên lớn (ephemeral), khác nhau mỗi kết nối. Cột `service` cho biết dịch vụ nhận diện được (nếu không nhận ra thường là "-").

## 6. Giao thức tầng ứng dụng (mức sơ lược)

- **HTTP**: yêu cầu (GET lấy dữ liệu, POST gửi dữ liệu) và phản hồi (mã 200 thành công, 301/302 chuyển hướng, 404 không thấy, 500 lỗi máy chủ). Cột `trans_depth`, `response_body_len`, `ct_flw_http_mthd`.
- **DNS**: dịch tên miền ra IP bằng các bản ghi A, AAAA, CNAME, MX. Thường là một truy vấn và một phản hồi nhỏ.
- **FTP**: có kênh lệnh và kênh dữ liệu riêng. Cột `is_ftp_login`, `ct_ftp_cmd`.
- **SMTP, SSH**: biết chúng để làm gì và port mặc định.

## 7. Các số đo lưu lượng

| Nhóm | Cột thường gặp | Cần hiểu |
|---|---|---|
| Thời lượng | `dur` | Kết nối kéo dài bao lâu |
| Số gói | `spkts`, `dpkts` | Chiều đi (source) và chiều về (destination) |
| Số byte | `sbytes`, `dbytes` | Tỷ lệ hai chiều bất thường là dấu hiệu |

| | | |
|---|---|---|
| Tốc độ, tải | `rate`, `sload`, `dload` | Bit hoặc gói trên giây |
| Nhịp gói | `sinpkt`, `dinpkt`, `sjit`, `djit` | Khoảng cách giữa các gói và độ biến thiên (jitter) |
| Cỡ gói | `smean`, `dmean` | Kích thước gói trung bình mỗi chiều |

## 8. Các cột đếm theo ngữ cảnh

Các cột bắt đầu bằng `ct_` (ví dụ `ct_srv_src`, `ct_dst_ltm`, `ct_src_dport_ltm`) đếm số kết nối liên quan trong một cửa sổ gần nhất: cùng nguồn, cùng đích, cùng dịch vụ hay cùng port. Một nguồn mở rất nhiều kết nối tới nhiều port hoặc nhiều đích trong thời gian ngắn sẽ làm các cột này tăng vọt. Đây là cách để đặc trưng "nhìn" được hành vi trải dài nhiều kết nối, thay vì chỉ một kết nối đơn lẻ.

## 9. Các loại tấn công trong bộ dữ liệu (mức khái niệm)

Cột `attack_cat` cho biết loại tấn công, cột `label` là 0 (bình thường) hoặc 1 (tấn công). Mục đích học phần này là nhận ra dấu vết trong số liệu để thiết kế đặc trưng và đọc kết quả.

| Loại | Ý chính | Dấu vết kỳ vọng |
|---|---|---|
| Reconnaissance | Dò xét mạng, quét cổng tìm dịch vụ mở | Nhiều port đích khác nhau, ít byte, kết nối ngắn, nhiều RST |
| DoS | Làm quá tải dịch vụ | Số kết nối hoặc gói rất lớn trong thời gian ngắn |
| Fuzzers | Gửi dữ liệu bất thường để tìm lỗi | Kích thước và nội dung gói lạ |
| Exploits, Shellcode, Backdoor, Worms, Analysis, Generic | Các hình thái khai thác và lây lan khác | Học cụ thể khi gặp trong dữ liệu |

## 10. IDS, firewall và cách đánh giá

- **Firewall**: lọc theo luật (cho phép hoặc chặn theo IP, port, giao thức).
- **IDS**: quan sát lưu lượng và cảnh báo. Loại dựa trên chữ ký tìm mẫu đã biết, loại dựa trên bất thường tìm thứ khác thường so với bình thường.
- **Báo nhầm (FP)**: cảnh báo cho lưu lượng bình thường. **Bỏ sót (FN)**: không báo trước một cuộc tấn công thật.
- Trong đề tài: recall = bắt được bao nhiêu phần trăm tấn công thật, precision = trong số cảnh báo đưa ra có bao nhiêu phần trăm đúng.

## 11. Thực hành với Wireshark

### 11.1 Bài tập tự làm

1. Cài Wireshark, bắt gói khi mở một trang web. Tìm DNS, bắt tay ba bước, rồi HTTP hoặc TLS.
2. Chọn một kết nối TCP, theo dõi từ SYN đến FIN. Đếm gói mỗi chiều và tổng byte, rồi so với cách bạn sẽ thấy trong một dòng dữ liệu.
3. `ping` một máy và xem ICMP. `nslookup` một tên miền và xem DNS.
4. Tìm một kết nối bị RST và giải thích vì sao.

### 11.2 Bộ lọc hay dùng

```
tcp.flags.syn == 1 && tcp.flags.ack == 0   gói mở đầu kết nối
tcp.flags.reset == 1                         kết nối bị hủy
tcp.analysis.retransmission                  gói truyền lại
dns          http          icmp              lọc theo giao thức
ip.addr == 192.168.1.10                      lọc theo IP
tcp.port == 443                              lọc theo port
```

> **An toàn:** chỉ bắt gói trên mạng của bạn. Nếu thử công cụ quét như Nmap thì chỉ làm trên máy ảo hoặc máy của chính bạn trong mạng lab riêng, không quét máy hay mạng thuộc người khác.

## 12. Lộ trình 3 tuần

### Tuần 1

☐ Nắm kết nối 5 thành phần, 4 tầng TCP/IP, IP và TTL (mục 1-2).
☐ Hiểu bắt tay ba bước và các cờ (mục 3.1-3.2).
☐ Cài Wireshark, làm bài tập 11.1 số 1-2.

### Tuần 2

☐ Cửa sổ, RTT, mất gói, trạng thái kết nối (mục 3.3-3.4).
☐ UDP, ICMP, port và dịch vụ (mục 4-5).
☐ Làm các bài Wireshark về TCP, UDP, ICMP, DNS, HTTP.

### Tuần 3

☐ Số đo lưu lượng, cột `ct_`, các loại tấn công (mục 7-9).
☐ Mở UNSW-NB15 và giải thích từng cột bằng kiến thức đã học.
☐ Đọc IDS, firewall, FP và FN (mục 10).

## 13. Tự kiểm tra

1. Kể lại bắt tay ba bước và nói cờ nào xuất hiện ở mỗi bước.
2. Vì sao một kết nối UDP có nhiều cột TCP bằng 0?
3. Quét cổng để lại những dấu vết gì trong `dur`, `sbytes`, `ct_*` và `state`?
4. Vì sao TTL cho biết một phần về máy gửi?
5. Khi nhìn một dòng dữ liệu, bạn có kể lại được kết nối đó dùng giao thức gì, gói đi nhiều hay về nhiều, kết thúc bình thường hay bị ngắt không?

Nếu trả lời được câu 5 cho hầu hết các dòng bạn mở ngẫu nhiên, bạn đã đủ nền mạng cho đề tài.